

Clase 270 — Ataques a RFID y NFC

Parte: **13 — Seguridad móvil, IoT e inalámbrica** · Fuente: *Practical IoT Hacking* (Chantzis et al.) y documentación de Proxmark3 📄 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Comprender y auditar tecnologías RFID de baja frecuencia (125 kHz) y alta frecuencia/NFC (13.56 MHz): cómo funcionan las tarjetas de acceso y de transporte, sus debilidades criptográficas históricas (MIFARE Classic/Crypto-1), y cómo leer, analizar y clonar tags **proprios** con un Proxmark3. El alumno también entenderá los riesgos de los sistemas de control de acceso basados en credenciales de proximidad y cómo endurecerlos.

⚠️ **Nota ética:** clona, lee o emula únicamente tarjetas de tu propiedad o con autorización explícita. Duplicar credenciales de acceso ajenas o defraudar sistemas de transporte/pago es delito.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** RFID LF (125 kHz) de HF/NFC (13.56 MHz) y sus estándares.
2. **Leer** e identificar tags con un Proxmark3.
3. **Explicar** la debilidad de MIFARE Classic (Crypto-1) y los ataques nested/darkside.
4. **Recuperar** claves y volcar el contenido de una tarjeta MIFARE propia.
5. **Clonar** un tag propio a una tarjeta regrabable (magic card).
6. **Recomendar** controles para sistemas de acceso por proximidad.

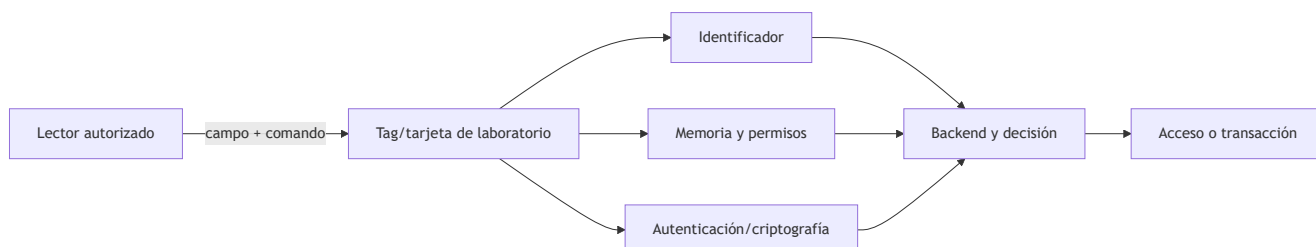
📖 Temas

#	Tema	Por qué importa
1	Fundamentos RFID/NFC	Base de acceso, transporte y pago
2	LF 125 kHz (EM4100/HID)	Credenciales de acceso comunes y débiles
3	HF/NFC 13.56 MHz (MIFARE, NTAG)	Tarjetas más extendidas
4	Crypto-1 y ataques a MIFARE	Cifrado roto ampliamente desplegado
5	Proxmark3: lectura y volcado	Herramienta de referencia
6	Clonado y magic cards	Demostrar el impacto
7	Endurecimiento de accesos	Migrar a DESFire, validar en backend

Explicación en profundidad

Frecuencia y forma no determinan el control de acceso

RFID agrupa tecnologías distintas; NFC opera a corta distancia en 13,56 MHz y define modos e interoperabilidad. Una tarjeta puede emitir un identificador fijo, autenticar criptográficamente o ejecutar una aplicación compleja. Leer un UID no equivale a clonar una credencial funcional, y copiar memoria no reproduce necesariamente claves, contadores o backend.



El diagrama coloca la decisión fuera del medio físico. Un sistema que autoriza solo por UID hereda riesgo de copia; uno con desafío-respuesta debe proteger claves y evitar replay; el backend puede detectar estado y revocar. La distancia corta reduce exposición casual, pero no es autenticación.

El laboratorio utiliza tarjetas compradas para práctica y un lector propio, sin credenciales de transporte, pago o acceso real. Se identifica tecnología, se lee información pública, se cambia una clave de laboratorio y se demuestra restauración. Recuperar claves débiles de MIFARE Classic enseña un diseño histórico concreto; no generaliza a todas las tarjetas ni autoriza clonar terceros.

Caso razonado: UID copiado sin acceso

Un emulador presenta el mismo UID, pero el lector exige respuesta criptográfica y contador coherente. La copia falla. El informe distingue la exposición del identificador de la resistencia de autenticación y revisa si el backend registra intentos. «Clonable» requería demostrar la transacción completa.



Glosario operativo

Término	Definición útil
UID	Identificador de tag; su estabilidad y seguridad dependen de tecnología.
Anticolisión	Procedimiento para seleccionar tags presentes simultáneamente.
Challenge-response	Autenticación que prueba conocimiento sin repetir una respuesta fija.
Replay	Reutilización de una comunicación anterior.
Sector/block	Organización de memoria presente en algunas familias de tarjetas.



Criterio de dominio

Existe dominio cuando el alumno identifica la tecnología, separa UID, memoria, criptografía y backend, reproduce una prueba solo con tarjetas propias y calibra la conclusión al control realmente demostrado.

Definiciones y características

- **RFID LF (125 kHz):** tags simples tipo EM4100/HID Prox que suelen transmitir solo un ID sin cifrado. Característica: clonables trivialmente.
- **NFC (13.56 MHz):** subconjunto de HF para comunicación de corto alcance (pagos, tags NTAG). Característica: soportado por smartphones.
- **MIFARE Classic:** tarjeta HF con el cifrado propietario Crypto-1. Característica: roto; sus claves se recuperan en segundos/minutos.
- **Proxmark3:** herramienta versátil de lectura/escritura/emulación RFID LF y HF. Característica: soporta ataques a MIFARE y clonado.
- **Ataque nested/darkside:** técnicas que explotan debilidades de Crypto-1 para recuperar claves de sectores. Característica: requieren al menos una clave o son de fuerza reducida.
- **Magic card:** tarjeta con bloque 0 regrabable que permite fijar un UID arbitrario. Característica: usada para clonar MIFARE Classic.

Herramientas y preparación

- **Proxmark3** (RDV4/Easy) con firmware Iceman, o **ACR122U** para NFC básico.
- **libnfc/mfoc/mfcuk** en Linux para MIFARE; **NFC Tools** en móvil.
- Tarjetas y tags **propios**; magic cards para pruebas de clonado.

```
# Proxmark3 (cliente Iceman)
pm3
[usb] pm3 → hf search          # detectar tarjeta HF/NFC
[usb] pm3 → lf search          # detectar tag LF
# MIFARE Classic: recuperar claves y volcar
[usb] pm3 → hf mf autopwn      # ataque automatizado (tarjeta propia)
```

Laboratorio guiado

1. **Identifica tus tags:** con `lf search` y `hf search` determina la tecnología de tarjetas propias.
2. **LF simple:** lee un EM4100 propio (`lf em 410x reader`) y observa que solo entrega un ID.
3. **HF/NFC:** con `hf 14a info` obtén UID, ATQA/SAK y el tipo de MIFARE.
4. **Ataca MIFARE Classic (propia):** ejecuta `hf mf autopwn` (o `mfoc`) para recuperar claves de los sectores.
5. **Vuelca la tarjeta:** genera el dump completo y ábrelo para inspeccionar los datos de los bloques.
6. **Clona a magic card:** escribe el dump y fija el UID en una magic card y verifica que el lector la reconoce igual.
7. **Analiza NTAG/NDEF:** lee un tag NTAG213 propio y su registro NDEF con NFC Tools.
8. **Propón mitigaciones:** documenta por qué migrar a DESFire EV2/3 y validar en backend.

Ejercicios

1. Identifica y clasifica tres tags propios por frecuencia y estándar.
2. Extrae el ID de un tag LF EM4100 propio.
3. Recupera las claves de una MIFARE Classic propia y explica qué ataque se usó.
4. Vuelca y analiza los sectores de una tarjeta propia.
5. Clona un tag propio a una magic card y verifica la lectura.

6. Redacta tres recomendaciones para endurecer un sistema de acceso por proximidad.

Reto verificable

Recupera todas las claves de una tarjeta MIFARE Classic **de tu propiedad**, vuelca su contenido y clónala a una magic card. **Criterio de aceptación:** el clon es reconocido por el mismo lector que la original (mismo UID y datos), y documentas qué ataque recuperó las claves y por qué Crypto-1 lo hizo posible.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
hf_search no detecta nada	Tag HF fuera de antena o es LF; prueba lf_search
autopwn no recupera claves	Tarjeta no es Classic (DESFire) o hardened; usa otra técnica
La emulación de UID no funciona en el lector	El sistema valida memoria, autenticación, estado o backend. Documenta qué capa rechazó la tarjeta; no intentes copiar una credencial real.
Magic card rechaza el UID	Tipo de magic (gen1a/gen2) equivocado; usa el comando adecuado
Lecturas intermitentes	Mala posición/antena; centra el tag sobre la antena

Preguntas frecuentes

 **¿Por qué MIFARE Classic sigue en uso si su cifrado está roto?** Por costo e inercia de despliegue. Muchos sistemas heredados no se han migrado, aunque las alternativas seguras (DESFire) existen desde hace años.

 **¿Clonar un tag LF es realmente tan fácil?** Sí: la mayoría solo emite un ID sin autenticación, así que leerlo y reescribirlo en un tag regrabable basta. Por eso no debe usarse como único control de acceso.

 **¿Puedo clonar tarjetas de pago o transporte con esto?** No de forma útil ni legal: los sistemas de pago usan criptografía fuerte y validación en backend; intentarlo es fraude.

Referencias

- Proxmark3 (Iceman): <https://github.com/RfidResearchGroup/proxmark3>
- libnfc/mfoc: <https://github.com/nfc-tools>
- Investigación sobre Crypto-1 (Nohl, Garcia et al.) — publicaciones académicas de la ruptura de MIFARE.
- Practical IoT Hacking*, caps. de RFID — Chantzis et al.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 269 — Radio definida por software \(SDR\)](#)

Siguiente clase

[Clase 271 — Seguridad de Bluetooth y BLE](#)